

机器学习中的攻击与防御

原创 毛婷伟、梁玉 腾讯安全智能 2019-12-23

导语：得益于互联网、云计算等技术的发展，如今各式各样的数据可以被很高效的收集起来，用以训练机器学习模型，进一步提供各式各样的AI服务，例如语音识别、机器翻译、自动驾驶等。然而，在AI得以广泛应用的过程中，其自身的安全性也同样值得关注。在“数据-模型-服务”这条典型的AI生产链路中，作为生产者，我们需要保证服务的可靠性、AI模型以及数据的私密性，这需要我们关注AI系统的安全性问题。本文将介绍AI应用过程中模型的安全性，内容上包括AI模型面临的安全风险、针对AI模型的攻击方法，以及可能的防御手段。

1.AI模型面临的安全风险

在大部分的AI应用场景中，AI模型的生产和服务的流水线可以抽象成图1所示的结构：

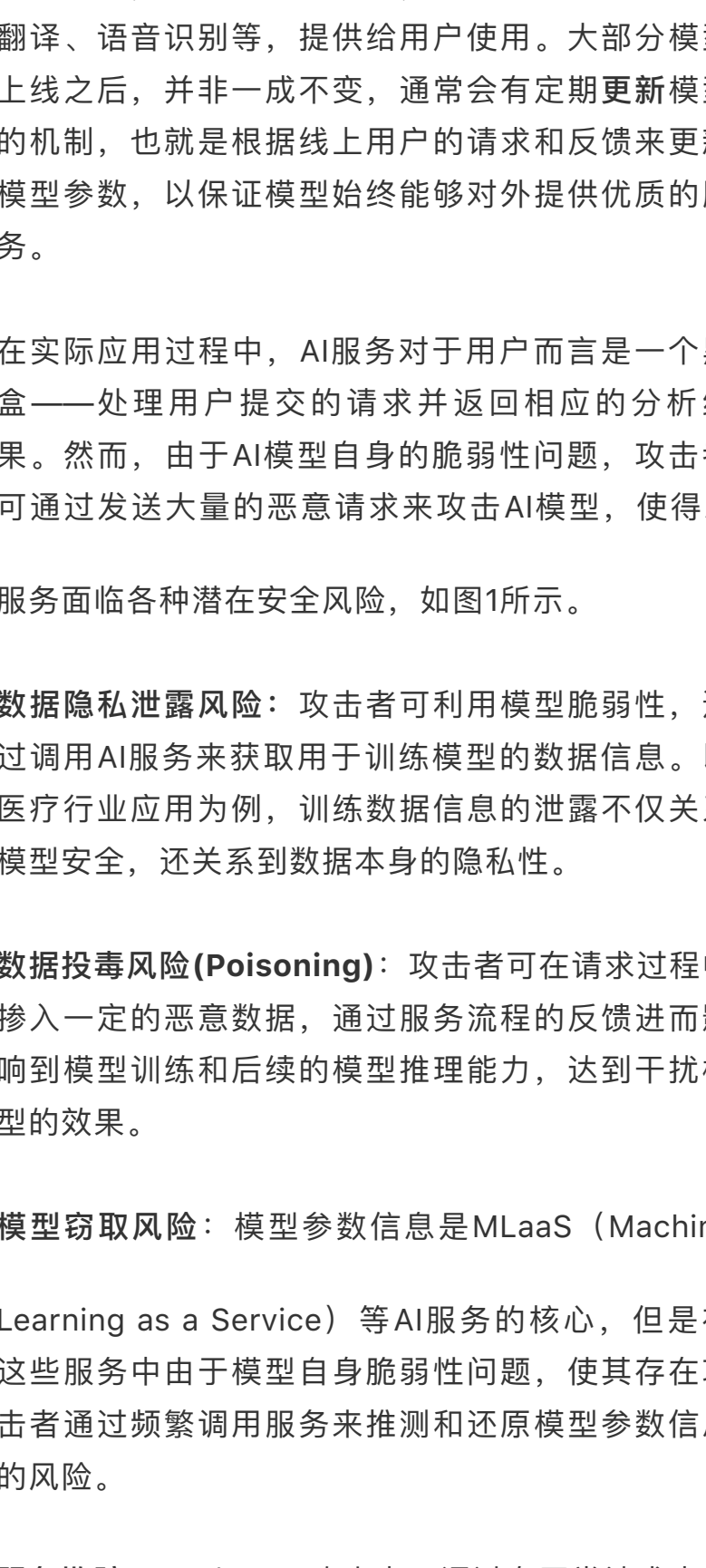


图1 AI模型的服务流程及其面临的安全风险

首先针对模型要解决的问题，收集相关数据，简单预处理之后将数据输入到模型中进行训练；在训练得到模型参数、并通过测试集测试之后，将模型部署到线上，成为一个AI服务，例如识别人脸、文字翻译、语音识别等，提供给用户使用。大部分模型上线之后，并非一成不变，通常会有定期更新模型的机制，也就是根据线上用户的请求和反馈来更新模型参数，以保证模型始终能够对外提供优质的服务。

在实际应用过程中，AI服务对于用户而言是一个黑盒——处理用户提交的请求并返回相应的分析结果。然而，由于AI模型自身的脆弱性问题，攻击者可通过发送大量的恶意请求来攻击AI模型，使得AI服务面临各种潜在安全风险，如图1所示。

数据隐私泄露风险：攻击者可利用模型脆弱性，通过调用AI服务来获取用于训练模型的数据信息。以医疗行业应用为例，训练数据信息的泄露不仅关系模型安全，还关系到数据本身的隐私性。

数据投毒风险(Poisoning)：攻击者可在请求过程中掺入一定的恶意数据，通过服务流程的反馈进而影响到模型训练和后续模型推理能力，达到干扰模型的效果。

模型窃取风险：模型参数信息是MLaaS（Machine Learning as a Service）等AI服务的核心，但是在这些服务中由于模型自身脆弱性问题，使其存在攻击者通过频繁调用服务来推测和还原模型参数信息的风险。

服务欺骗(Evasion)：攻击者可通过在正常请求中加入少量噪音、扰动，使得AI服务做出错误的判断。一个典型案例是，腾讯科恩实验室曾在今年的3月指出特斯拉Autopilot系统中的一个图像识别服务缺陷——通过在车的挡风玻璃正前方部署的画面图像，成功欺骗图像识别服务打开雨刷开始工作。

2.针对AI模型的攻击方法

对于AI模型的脆弱性研究，学术界已有一定的研究成果，其中对于AI模型的攻击方法，可简单总结为如下三类：

欺骗攻击：又可称为绕过攻击，指的是在不干扰模型训练过程的情况下，如何绕过AI系统的检测，使得攻击者能够因此在某些系统中取得非法的权限等。

注入攻击：也可称为恶意注入攻击，指的是攻击者通过向模型的训练集中注入精心构造的恶意样本，使得模型能够帮助攻击者完成预设的功能，如触发后门、误分类等。

隐私攻击：亦可称为逆向攻击，指的是攻击者在无法使用AI应用或者仅仅能调用AI服务的API时，如何推测相关信息，如AI模型的训练集、参数或者优化算法等。

a) 欺骗攻击

AI模型的脆弱性是导致欺骗攻击得以发展的主要原因之一。**AI模型的脆弱性**指的是AI模型容易被攻击者“gamed”，攻击者通过对输入数据的简单干扰，便使得AI模型的输出与正常结果产生偏离。针对AI模型的脆弱性，Szegedy[1]等提出特征空间的高度非线性、不连续性是导致模型脆弱的重要原因，Goodfellow[2]提出AI模型中的高维、线性特点则是导致模型脆弱的基础原因。利用AI模型的脆弱性，攻击者可以根据模型的输出不断的调整恶意样本，最终能够利用该恶意样本绕过AI模型的检测。用于绕过AI模型的样本也被称为对抗样本，它具有不易被人类察觉、能够被模型误判的特点，目前针对欺骗攻击的研究大部分都聚焦在对抗样本的生成上，已有的对抗样本生成方法可以粗略的被分为两类，一类是基于生成模型的方法，一类是**最小化扰动**的方法，其中基于生成模型的方法以**GAN(Generative Adversarial Network)**为代表，而最小化扰动的方法则以Goodfellow提出的FGSM方法[2]为代表。

基于GAN的欺骗攻击：GAN最早是CV中用来生成样本的，它的结构如下，一个基本的GAN是由一个生成器G和一个判别器D构成的，生成器和判别器都是深度学习模型，他们分别接受不同的输入。一个基础款的GAN接受一个随机噪声向量，输出一个合成样本，随后合成的样本和真实的数据被送入判别器D，让判别器区分合成数据和真实数据，一个好的生成器G能够生成判别器无法判断的样本，一个好的判别器D能够区分出合成数据和真实数据。据此博弈的思想，GAN以定义如公式(1)所示的目标函数，并通过优化该目标函数，得到理想的生成器G和判别器D。

攻击者可以使用基于GAN训练得到的生成器G来生成对抗样本、攻击AI模型，例如生成一个假人脸图像来欺骗人脸识别模型。基于GAN的方法可以让攻击者批量的生成对抗样本。

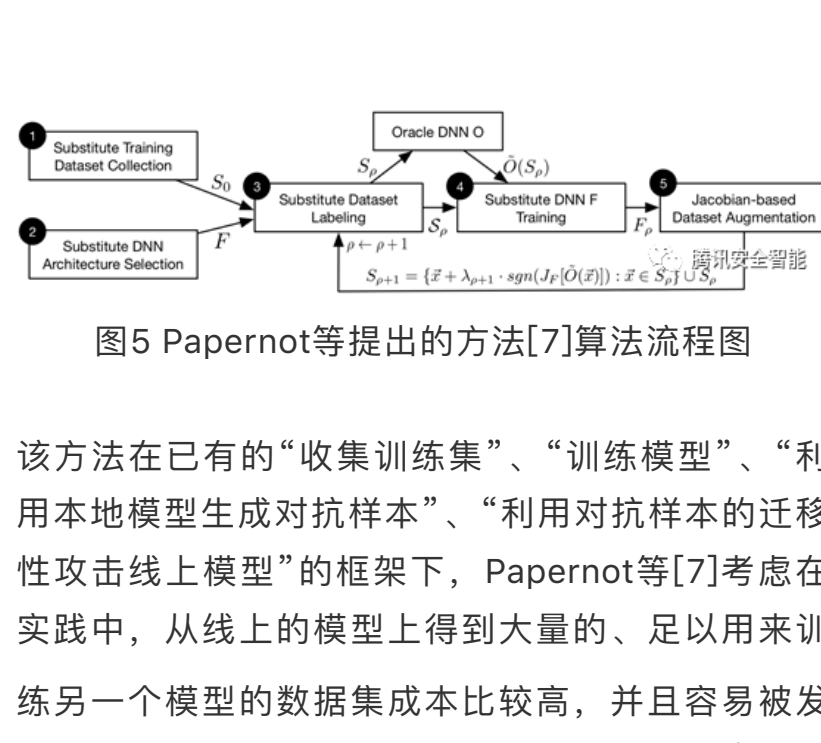


图2：基于GAN的欺骗攻击流程

最小化扰动的欺骗攻击：该攻击主要是通过修改事先准备好的恶意样本来实现攻击。与GAN不同的是，该攻击不是从一个随机噪声开始，它是在已有的一个样本基础上，通过在样本上添加扰动来实现攻击。Papernot等[3]将该类攻击的过程划分为“方向敏感性估计”和“选择扰动”两个步骤，分别来解决“在哪添加扰动”和“添加多少扰动”的问题。具体的，“方向敏感性估计”用来估计对模型结果影响最大的位置，“选择扰动”则在估计的位置上施加相应的修改措施，使得扰动最小，但对模型结果改变最大，每次选择扰动之后，判断模型的输出是否满足攻击目标，如果满足，则输出扰动后的样本为一个对抗样本，否则继续进行“方向敏感性估计”和“选择扰动”上的迭代。

在最小化扰动的攻击中，已有的方法主要是基于梯度的方法，思路是利用目标函数，对输入X求偏导，由于梯度方向为对模型输出影响最大的方向，因此将输入沿着梯度方向行走，便可以造成对模型输出的最大影响，具有代表性的方法有FGSM(Fast Gradient Sign Method)[2]，该方法的更新如公式(2)：

$$(2)$$

其中为J目标模型的代价函数，y_true为输入X的真实标签，在公式（2）的迭代方式下，能够很快使得F(X_*)不等于y_true，从而实现攻击。与此方法类似，还有一种利用梯度方向的方法[12]，不同的是，它利用负梯度方向为函数下降最快的方向，将公式(2)稍稍修改，便可以得到该方法的更新：

$$(3)$$

其中y_target为攻击者想要模型输出的标签，在该公式的迭代下，能够很快得到使得F(X_*)=y_target的样本，从而实现定向攻击。结合Papernot等[3]两阶段的思路，可以看到上述两类方法利用梯度扰动输入的所有维度，之后给予某个扰动量，从而实现攻击。基于上述两种思路，学术界延伸出了多种变体，多数是为了解决扰动过大（扰动所有维度）的问题，例如限制一次迭代中，更新最大不超过某个阈值或针对每个输入位置，扰动不得超过某个阈值（调整ε）等。

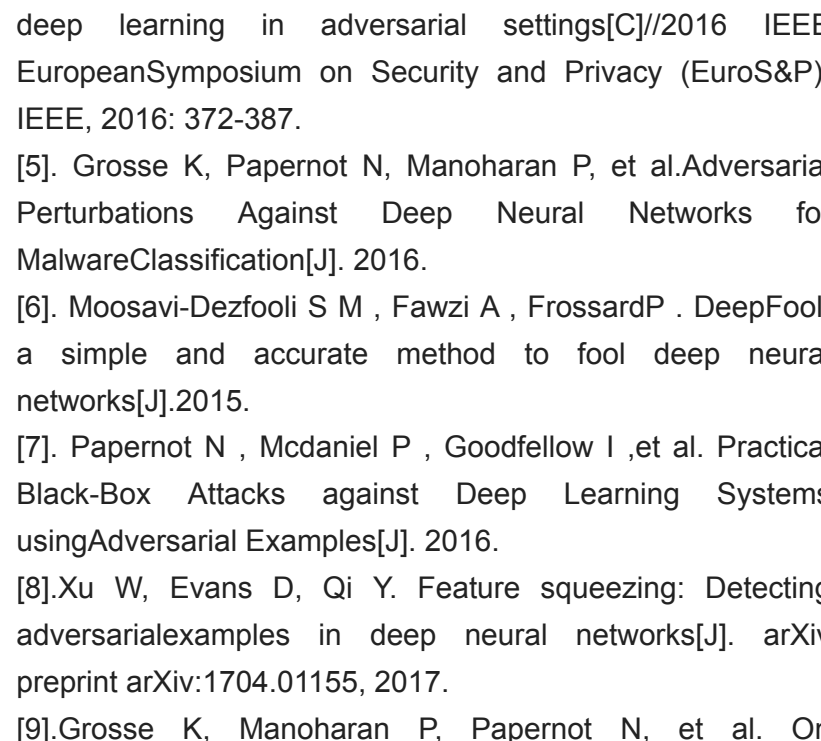


图3 Papernot等基于两阶段的攻击方法

在基于梯度的方法之外，还有一种攻击，它仅仅允许对少量位置进行扰动。也就是说，攻击的时候，需要选择尽可能少的位置进行干扰，且扰动要尽可能的小。一种代表性的方法为JSA（Jacobian Saliency Map Algorithm）[4]方法，它在“方向敏感性估计”的步骤上，利用对抗性攻击图(Adversarial Saliency Maps)找到对模型结果影响最大的有限个点，然后在这些点上增加扰动。对抗性显著图的计算如公式(4)所示，

$$S(\mathbf{X}, t)[i] = \begin{cases} 0 & \text{if } \frac{\partial F(\mathbf{X})}{\partial X_i} < 0 \text{ or } \sum_{j \neq i} \frac{\partial F(\mathbf{X})}{\partial X_j} > 0 \\ \left(\frac{\partial F(\mathbf{X})}{\partial X_i} \right) / \sum_{j \neq i} \left(\frac{\partial F(\mathbf{X})}{\partial X_j} \right) & \text{otherwise} \end{cases} \quad (4)$$

其中X为输入，t是目标类别，也就是通过对X的扰动，使得模型对X的输出为t。由于分类模型判断类别是根据输出层的概率值来的，所以要想其他类别将X判断为t，需要使F_t的取值增大，或者将其类别的输出层概率减小，因此当输出层对X_i的偏导为正数时，表示X_i上的值增加，能够带来输出层概率的增加，具有较大的显著性，反之，则显著性较小，此处是直接置0。将非类别的输出层概率减小是类似的逻辑，此处不再赘述。得到对抗性显著图之后，可以选择其中值最大的点进行修改，也就是将X_i=X_i+ε，然后观察是否实现攻击，若无，则继续迭代，直到攻击成功。

b) 注入攻击

注入攻击利用的主要是AI模型对训练集中数据分布的依赖，一个分类模型所定义的分类边界是会被训练集中的数据所影响的，例如支持向量会决定着SVM中的超平面。因此，攻击者可以通过向训练集中注入样本或者改变训练集中的数据分布来攻击模型。在AI模型的训练阶段，通过将恶意样本注入到训练集中，攻击者可以非常容易的为自己留后门；在模型被发布以后，攻击者可以利用反馈的逻辑，通过大量构造输入样本，来改变线上的数据分布，从而影响模型的更新，实现对模型的攻击，注入攻击方法的流程图如下[11]：

图4 注入攻击类方法攻击流程图

c) 隐私攻击

在该类攻击手法中，最常见的一类是**模型窃取**。若训练好的模型被部署在MLaaS平台上，那么攻击者可以通过API来请求模型的输出，攻击者可以构造与训练集同分布的样本，以API请求的方式来获得模型的输出，这样便可得到一个本地的训练集，用该训练集重新训练一个模型，那么该模型则将与MLaaS上的模型类似，尤其在攻击者知道模型结构、超参数与参数的情况下，甚至本地模型的效果能与发布的模型不相上下，从而实现对模型的盗用。更严重的是，当攻击者利用该攻击方式生成一个本地的替代模型时，那么他便可以在完全白盒的情况下生成一系列对模型的对抗样本，来实现对模型的绕过。据已有的研究成果发现，对抗样本在模型间是具有可迁移性的，换言之，攻击者利用本地模型生成的对抗样本，完全可以用来攻击**MLaaS上的模型**。已有的该类攻击手法以Papernot等提出的方法[7]为代表，它仅仅需要攻击者构造少量的样本，便可以实现对模型的盗用，该方法的攻击流程如下图：

图5 Papernot等提出的方法[7]算法流程图

该方法在已有的“收集训练集”、“训练模型”、“利用本地模型生成对抗样本”、“利用对抗样本的迁移性攻击线上模型”的框架下，Papernot等[7]考虑在实践中，从线上的模型上得到大量的、足以用来训练另一个模型的数据集成本比较高，并且容易被发现，所以提出了一种利用雅可比进行数据增广的方法，使得攻击者能够在小的训练集的基础上，通过迭代的策略，一步步的扩充训练集，优化模型，从而把线上的模型盗出，是一种实践性很强的攻击方法。

此外，还有一些攻击者会进行**成员推断**，也就是判断某个样本是否在模型的训练集中，或利用某个数据的部分特征，反推其他特征的取值。由于涉及到复杂的技术手段，关于成员推断攻击和模型逆向，会在后续文章中介绍。

3.针对AI攻击的防御手段

针对AI模型中可能会存在的各种风险，已有的防御手段可以简单总结如下：

- **增加对抗样本识别模块**——对模型的输入数据，先判定是否是对抗样本[8][9][10]。在该类防御手段下，有些方法通过对特征降维、筛选、去噪等手段来预处理输入，并将预处理后的样本输入模型，之后将模型对该样本的输出与原始样本的模型输出对比，如果差别较大，则认为是对抗样本。
- **通过机器学习的手段，增强模型的鲁棒性**[1]，例如在训练阶段加入对抗训练的过程、通过适当的数据增广来丰富训练数据集，使得模型对扰动、噪声、形变等鲁棒性更强。
- **在模型输出阶段，减少不必要的输出**，例如在分类模型中，直接输出类标签，而不附加置信度等信息，从而提高攻击者的攻击成本。

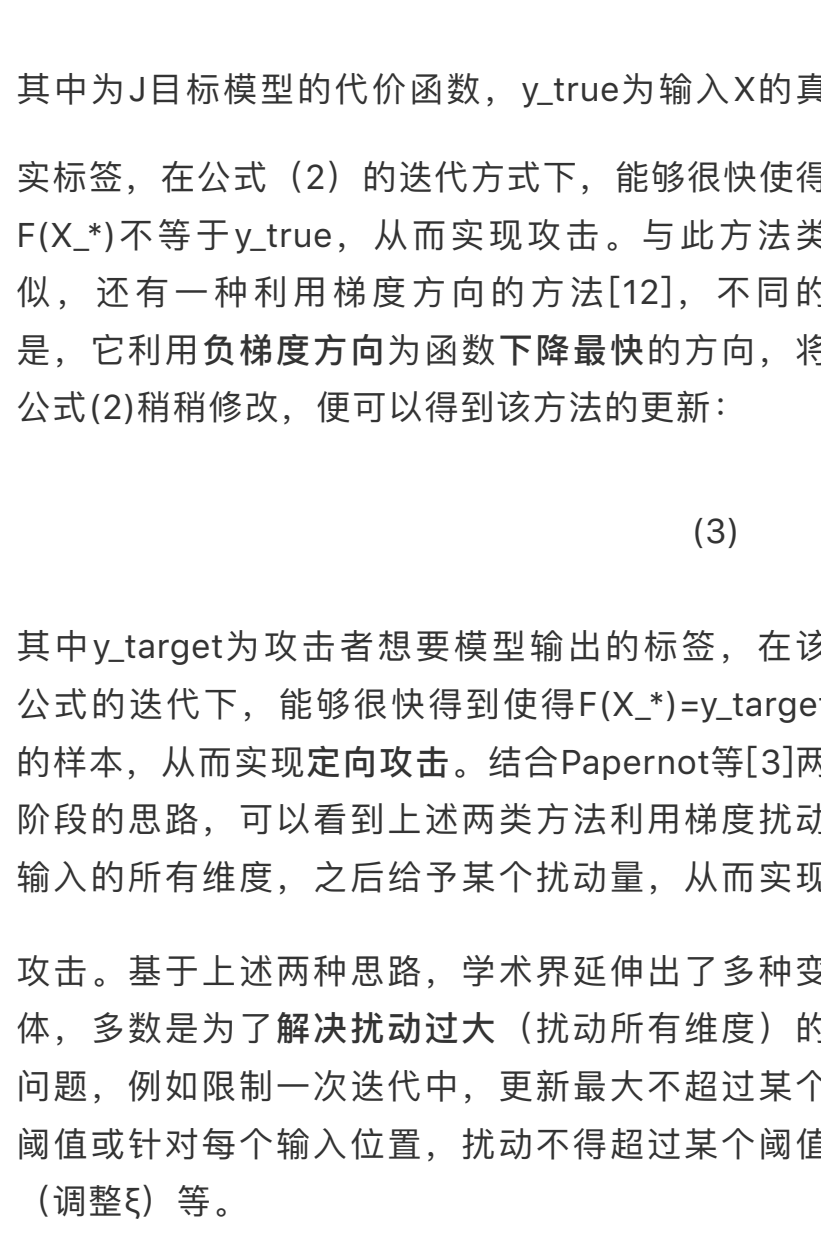
另外有一些**集成、蒸馏[3]、混淆**等手段，也可用于有效的提高模型鲁棒性，提高攻击者的攻击成本。

结语

目前，学术界针对文中所述的三种类型的攻击已有一定的研究成果，但成果中实现攻击所需要的条件、以及适用的模型和应用领域还比较局限，例如大部分的成果需要在白盒条件下进行，也就是说攻击者需要知道模型的参数、训练算法、结构、甚至激活函数、训练集等，虽然可以通过模型盗取的方案把黑盒条件下的攻击转化为白盒，但此方法仍具有较大的局限性，且缺乏实际的对抗经验。此外，研究中所针对的数据大部分也都是图像数据，但众所周知，除了图像数据，还有很多其它类型的场景、数据和更加复杂的模型值得关注。【腾讯安全智能】会紧跟AI安全前沿研究，并积极探索AI领域中的安全对抗方案。

参考文献

- [1]. Szegedy C, Zaremba W, Sutskever I, et al. Intriguing properties of neural networks[J]. arXiv preprint arXiv:1312.6199,2013.
- [2]. Goodfellow I J, Shlens J, Szegedy C. Explaining and harnessing adversarial examples[J]. arXiv preprint arXiv:1412.6572, 2014.
- [3]. Papernot N, McDaniel P, Wu X, et al. Distillation as a defense to adversarial perturbations against deep neural networks[C]//2016 IEEE Symposium on Security and Privacy (SP). IEEE, 2016:582-597.
- [4]. Papernot N, McDaniel P, Jha S, et al. The limitations of deep learning in adversarial settings[C]//2016 IEEE European Symposium on Security and Privacy (EuroS&P). IEEE, 2016: 372-387.
- [5]. Grosse K, Papernot N, Manoharan P, et al. Adversarial Perturbations Against Deep Neural Networks for Malware Classification[J]. 2016.
- [6]. Moosavi-Dezfooli S M, Fawzi A, Frossard P. DeepFool: a simple and accurate method to fool deep neural networks[J]. 2015.
- [7]. Papernot N, McDaniel P, Goodfellow I, et al. Practical Black-Box Attacks against Deep Learning Systems using Adversarial Examples[J]. 2016.
- [8]. Xu W, Evans D, Qi Y. Feature squeezing: Detecting adversarial examples in deep neural networks[J]. arXiv preprint arXiv:1704.01155, 2017.
- [9]. Grosse K, Manoharan P, Papernot N, et al. On the (statistical) detection of adversarial examples[J]. arXiv preprint arXiv:1702.06280, 2017.
- [10]. Metzen J H, Genewein T, Fischer V, et al. On detecting adversarial perturbations[J]. arXiv preprint arXiv:1702.04267, 2017.
- [11]. Ibitoye O, Abou-Khamis R, Matrawy A, et al. The Threat of Adversarial Attacks on Machine Learning in Network Security--A Survey[J]. arXiv preprint arXiv:1911.02621, 2019.
- [12]. Kurakin A, Goodfellow I, Bengio S. Adversarial machine learning at scale[J]. arXiv preprint arXiv:1611.01236, 2016.



该账号主要围绕智能化技术如何帮助企业提升网络安全水平展开，内容涉及机器学习、大数据处理等智能化技术在安全领域的实践经验分享，业界领先的产品和前沿趋势的解读分析等。通过分享、交流，推动安全智能的落地、应用。欢迎关注~

QQ浏览器热搜榜

- 1 白岩松谈张玉环案 876.5w人在搜
- 2 深航客机遇紧急情况骤降近6千米 796.8w人在搜
- 3 TikTok最早将于周二提起联邦诉讼 724.3w人在搜
- 4 26岁女博士获聘湖南大学副教授 658.5w人在搜
- 5 黎巴嫩爆发反政府示威活动 495.4w人在搜

[查看全部榜单 >](#)